

AWS IAM 정책 및 S3 Bucket Policy 권한 분석 보고서

1. 과제 개요

문제 상황

IAM 사용자 user01에게 하나의 IAM 정책이 부여되어 있으며, 동시에 S3 Bucket Policy가 설정되어 있다.

두 정책이 함께 적용될 때 user01이 실제 수행할 수 있는 작업을 분석하고 AWS 정책 평가 우선순위를 이해하는 것이 목적이다.

2. 정책 내용 분석

2.1 IAM 정책

```
{  
  "Effect": "Allow",  
  "Action": "s3:*",  
  "Resource": "*"   
}
```

정책 의미

- Effect : Allow
 - S3 작업을 허용한다.
- Action : s3:*
 - S3의 모든 작업(Create, Delete, Get, Put 등)을 허용한다.
- Resource : *
 - 모든 S3 리소스(버킷 및 객체)에 대해 적용된다.

즉, user01은 IAM 정책만 보면 S3의 모든 작업을 수행할 수 있다.

2.2 S3 Bucket Policy

```
{  
  "Effect": "Deny",  
  "Principal": "user01",  
  "Action": "s3:PutObject",  
  "Resource": "*"   
}
```

정책 의미

- Effect : Deny
 - 해당 작업을 명시적으로 거부한다.
- Principal : user01
 - user01 사용자에게 적용된다.
- Action : s3:PutObject
 - 객체 업로드(PutObject)를 거부한다.
- Resource : *
 - 모든 버킷 및 객체에 적용된다.

즉, user01은 S3 객체 업로드를 수행할 수 없다.

3. 정책 평가 우선순위

AWS는 여러 정책이 동시에 존재할 경우 다음과 같은 순서로 권한을 평가한다.

1. Explicit Deny (명시적 거부)
2. Allow (허용)
3. 기본 Deny (권한 없음)

따라서 Allow 정책이 존재하더라도 Explicit Deny가 있으면 해당 작업은 수행할 수 없다.

4. 서비스별 허용 및 거부 예시

서비 스	작업(Action)	결과	이유
EC2	ec2:RunInstances	✗ 거 부	EC2 권한이 없음
	s3:CreateBucket	✓ 허 용	IAM 정책에서 허용
S3	s3:ListBucket	✓ 허 용	IAM 정책에서 허용
S3	s3:GetObject	✓ 허 용	IAM 정책에서 허용
S3	s3:DeleteObject	✓ 허 용	IAM 정책에서 허용
S3	s3:PutObject	✗ 거 부	Bucket Policy에서 Explicit Deny

5. 권한 분석 결과

IAM 정책에서는 user01에게 S3의 모든 작업(s3:*)을 허용하였다.

그러나 S3 Bucket Policy에서 user01의 PutObject 작업을 Explicit Deny 하였기 때문에 객체 업로드는 수행할 수 없다.

즉,

- 버킷 생성 가능
- 버킷 목록 조회 가능
- 객체 다운로드 가능
- 객체 삭제 가능
- 객체 업로드 불가능

이라는 결과가 된다.

6. 결론

이번 실습을 통해 IAM 정책과 S3 Bucket Policy가 동시에 적용될 경우 AWS의 권한 평가 우선순위를 확인할 수 있었다.

IAM 정책에서는 S3의 모든 작업을 허용하였지만, Bucket Policy에서 PutObject 작업을 Explicit Deny 하였기 때문에 객체 업로드는 수행할 수 없었다.

AWS에서는 Explicit Deny가 Allow보다 항상 우선 적용되므로 여러 정책을 함께 사용할 때는 Deny 정책이 있는지 반드시 확인해야 한다.